ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.02

Compromiso de la dirección y alcance del SGSI

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.02 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. Compromiso de la dirección y alcance del SGSI..... 3
A.1 Declaración de compromiso de la dirección..... 3
A.2 Alcance del SGSI..... 4
A.3 Revisión del alcance tras el BIA (versión 1.1, se entrega con E.03)..... 5
Supuestos declarados en este entregable..... 6
Revisión del alcance al cerrar el BIA..... 6

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos (E.01 v1.1)
Fecha de entrega	viernes 2 de octubre de 2026 (H1)
Versión del documento	v1.0 · 2 de octubre de 2026

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.02 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E02_Compromiso_Direccion_Alcance_SGSI_<Equipo>.docx (o .pdf).

3. Compromiso de la dirección y alcance del SGSI

Fundamento: ISO/IEC 27001:2022, cláusulas 4 (Contexto de la organización) y 5 (Liderazgo); función Gobernar de NIST CSF 2.0 (2024). Extensión de referencia: 2–3 páginas.

El equipo redacta cada campo de las tablas A.1 y A.2 en su segunda columna, en prosa completa por fila, y sustituye la descripción que trae la plantilla.

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · ENSA (IG3) · entrega: viernes 2 de octubre de 2026.

A.1 Declaración de compromiso de la dirección

Campo	Contenido que redacta el equipo
Encabezado	Energía Nacional S.A. de C.V. (ENSA), centro de operaciones de San Salvador, 2 de octubre de 2026. Firmantes simulados: Ing. Óscar Mauricio Handal, Gerente General, e Ing. Karla Beatriz Vásquez, Jefa de Seguridad de la Información (jefatura que crea la ficha de datos del cliente; su dependencia de la Gerencia General es el supuesto S-03).

Campo	Contenido que redacta el equipo
Contexto del negocio	ENSA distribuye energía eléctrica a clientes residenciales e industriales desde un centro de operaciones en San Salvador y subestaciones en todo el territorio, con 550 empleados. Los ingresos provienen del servicio distribuido y facturado: la operación de la red de control (SCADA/OT), la medición inteligente (AMI), la gestión de interrupciones (OMS) y el sistema comercial y de facturación (SAP IS-U) sostienen la totalidad del ciclo de ingreso. El perfil declara dependencia tecnológica crítica: un ciberataque exitoso puede causar un apagón de alcance nacional, de modo que la indisponibilidad afecta a terceros ajenos a la empresa y no solo a su resultado financiero.
Declaración de compromiso	La dirección de ENSA declara la seguridad de la información y de la tecnología de operación como prioridad del negocio, en el mismo rango que la seguridad eléctrica de las personas. Asigna a la Jefatura de Seguridad de la Información la autoridad para definir requisitos de seguridad exigibles a TI y a TO, para detener cambios que introduzcan riesgo no tratado y para reportar directamente a la Gerencia General. Adopta CIS Controls v8.1 (2024) como marco de control operativo e ISO/IEC 27001:2022 como marco del sistema de gestión, con NIST CSF 2.0 (2024) como lenguaje común de funciones. La dirección respalda el ciclo PDCA y la mejora continua del programa.
Objetivos de seguridad	Fechas contadas desde el arranque del programa que fija la ficha, el lunes 4 de enero de 2027. O-1: sostener la operación del sistema SCADA con un RTO de dos horas y una indisponibilidad no planificada menor a cuatro horas por evento, medida en el registro de incidentes del centro de control, a partir del 30 de junio de 2027. O-2: segmentar el 100 % de los puntos de conexión entre la red de TI y la red OT con un punto de filtrado documentado y aprobado, al 30 de junio de 2027. O-3: cubrir con autenticación multifactor el 100 % de los accesos remotos de proveedores y del personal administrador de TI y TO al 30 de junio de 2027. O-4: inventariar el 100 % de los activos de la red OT, incluidos concentradores AMI y equipos de subestación, al 30 de septiembre de 2027. O-5: notificar toda brecha de datos personales de clientes dentro de las 72 horas que exige la LPDP (D.L. 144/2024, art. 25) desde el 4 de enero de 2027, con un procedimiento probado antes del 31 de diciembre de 2027 y después una vez al año.
Compromisos concretos	Presupuesto aprobado para seguridad, copiado de la ficha de datos del cliente: USD 480 000 para 2027 (USD 310 000 de inversión y USD 170 000 de operación) y el mismo nivel para 2028 y 2029, sujeto a aprobación, que la Junta Directiva ajustaría entre USD 300 000 y 600 000 según los resultados del primer año. Personal: la Jefatura de Seguridad de la Información con tres plazas —jefatura, analista de seguridad de TI y analista de seguridad de TO— más la dedicación parcial declarada de dos ingenieros de la Gerencia de Operaciones de Red. Revisión por la dirección trimestral, con acta y decisiones registradas; revisión extraordinaria ante todo incidente de severidad alta. La dirección instruye que ningún proyecto de modernización de red inteligente se apruebe sin evaluación de riesgos previa.

La declaración se firma en el documento final (E.11, sección 2) y gobierna todos los entregables posteriores: los objetivos O-1 a O-5 reaparecen como indicadores en E.09 y como hitos del roadmap en E.10.

A.2 Alcance del SGSI

Campo	Contenido que redacta el equipo
Procesos cubiertos	Los cuatro procesos que el perfil declara críticos: Operación de la Red de Control (SCADA/OT), Gestión de Medición Inteligente (AMI), Sistema de Gestión de Interrupciones (OMS) y Sistema Comercial y de Facturación. Se incorporan al alcance, como procesos de soporte con efecto directo sobre los anteriores, la gestión de TI corporativa (identidad, correo y ofimática), la gestión de campo y cuadrillas con GIS y la atención al cliente. El BIA de E.03 confirma cuáles son críticos y con qué puntaje.

Campo	Contenido que redacta el equipo
Unidades y sedes	Gerencia General, Gerencia de Operaciones de Red, Gerencia Técnica, Gerencia Comercial, Finanzas y la unidad TI/TO. Sedes: centro de operaciones de San Salvador, incluido el centro de control de red y el centro de datos corporativo; las doce subestaciones principales del territorio; el centro de atención comercial.
Sistemas e infraestructura	Sistemas SCADA de Siemens y su red de tecnología operacional; cabecera de medición inteligente (AMI) y concentradores de datos; sistema de gestión de interrupciones (OMS); sistema de facturación SAP IS-U; plataforma de geolocalización (GIS); red corporativa de TI y sus servicios de identidad, correo y archivos; los puntos de conexión entre la red OT y la red de TI, que el perfil describe como inseguros.
Exclusiones justificadas	Red inalámbrica de invitados del edificio corporativo: no sostiene ningún proceso del alcance y se mantiene aislada de la red corporativa y de la red OT. · Sistemas de videovigilancia de las subestaciones: quedan bajo la Gerencia Técnica con un programa propio y entran al alcance en la revisión anual, porque su convergencia con la red OT no está resuelta. · Equipos de medición en poder del cliente: su seguridad física corresponde al titular del servicio, y el alcance cubre la cabecera AMI y los concentradores.
Partes interesadas y requisitos	Clientes residenciales e industriales; el ente regulador del sector eléctrico, con obligaciones de continuidad y calidad del servicio; el operador del sistema con el que ENSA intercambia información de operación; proveedores del sistema SCADA, de la plataforma AMI y del sistema comercial; el personal de campo. Requisitos legales: la Ley para la Protección de Datos Personales (D.L. 144/2024), cuyo artículo 25 obliga a notificar toda vulneración de los datos de consumo, de identificación y de ubicación de los clientes a la Agencia de Ciberseguridad del Estado, a la Fiscalía General de la República y a los titulares afectados en un máximo de 72 horas; la Ley de Ciberseguridad y Seguridad de la Información (D.L. 143/2024), registrada como requisito sujeto a que la Agencia califique a ENSA como operador con incidencia en las infraestructuras críticas de la nación (art. 2); las obligaciones de continuidad y calidad del servicio de la Ley General de Electricidad y de las Normas de Calidad del Servicio de los Sistemas de Distribución de la SIGET —indicadores de interrupción, reporte y compensaciones a los usuarios—, que la ficha registra en el bloque «Organización y presupuesto»; y las cláusulas de confidencialidad y de seguridad que ENSA exige a sus proveedores de tecnología de operación.

A.3 Revisión del alcance tras el BIA (versión 1.1, se entrega con E.03)

Se completa en la versión 1.1 de E.02, que se entrega junto con E.03: una fila por cada diferencia entre los procesos cubiertos por el alcance y la clase que BIA_P05 les asigna.

Proceso	Clase en BIA_P05	Diferencia con el alcance de la versión 1.0	Decisión (mantener o ajustar el alcance) y justificación
P-01 SCADA/OT y P-03 OMS	Crítico (6,31 y 4,62)	Sin diferencia: el alcance de la versión 1.0 los trata como críticos	Se mantienen, con tratamiento prioritario en E.05 y en el corto plazo de E.10
P-04 Sistema Comercial y Facturación y P-02 AMI	Importante (2,46 cada uno)	La versión 1.0 los cubría como críticos, tal como los declara el perfil	Se mantienen en el alcance como importantes; conservan su valoración en BIA_P02 (SLE-03, SLE-04 y SLE-05) y sus activos en E.04
P-09 TI corporativa, P-06 campo y cuadrillas con GIS y P-05 atención al cliente	Importante (2,80, 2,59 y 1,93)	Sin diferencia: la versión 1.0 los incorpora como procesos de soporte	Se mantienen, porque sostienen a los procesos críticos
P-10 contabilidad y reportes regulatorios, P-08 nómina y P-07 compras	Diferible (1,65, 1,65 y 1,60)	La versión 1.0 no los nombra; el censo de BIA_P01 los añadió como procesos de soporte	Se incorporan al alcance como diferibles, con el respaldo de sus datos y un tiempo de recuperación declarado

Versión 1.1 de E.02, entregada junto con E.03 el viernes 16 de octubre de 2026.

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
S-03	La Jefatura de Seguridad de la Información que la ficha crea con tres plazas depende de la Gerencia General.	La ficha crea la jefatura y las plazas de analista de seguridad de TI y de TO sin fijar a quién reporta la jefatura; el proyecto necesita un rol que apruebe, ejecute y verifique.
S-04	Sin uso: las obligaciones de continuidad y calidad del servicio son un dato de la ficha (bloque «Organización y presupuesto»: Ley General de Electricidad y Normas de Calidad del Servicio de los Sistemas de Distribución de la SIGET), y un dato de la ficha nunca se sustituye por un supuesto.	El identificador se conserva para no alterar la numeración global S-01 a S-17.
S-05	Sin uso: el presupuesto de USD 480 000 y las tres plazas son datos de la ficha (bloque «Organización y presupuesto»), y un dato de la ficha nunca se sustituye por un supuesto.	El identificador se conserva para no alterar la numeración global S-01 a S-17.
S-06	Sin uso: las doce subestaciones principales con equipo de control conectado al SCADA son un dato de la ficha (bloque «Economía», con un rango de 8 a 20), y un dato de la ficha nunca se sustituye por un supuesto.	El identificador se conserva para no alterar la numeración global S-01 a S-17.

Revisión del alcance al cerrar el BIA

El alcance declarado aquí se revisó al cerrar E.03, como pide el método del proyecto. El puntaje de criticidad de BIA_P05 confirmó como críticos dos de los cuatro procesos que el perfil declara, SCADA/OT (6,31) y OMS (4,62), y clasificó como importantes al Sistema Comercial y Facturación y a AMI, con 2,46 cada uno: a las veinticuatro horas ninguna de sus calificaciones pasa de 3, y la ficha sitúa la reacción del regulador en la semana o el mes. Los cuatro procesos permanecen en el alcance. La gestión de TI corporativa, importante con 2,80, sigue dentro por su papel en la identidad y el acceso, que es la vía de entrada de dos de los tres riesgos Críticos de E.05.